



Cloud - Public API

O módulo 'Public API' da solução é disponibilizado para aplicações que desejam utilizar recursos criptográficos com certificados armazenados em nuvem.

O módulo disponibiliza funções para os serviços de:

- > Registro de aplicações
- > Descoberta de usuário(s)
- > Autenticação Web (oAuth2 AuthorizationCode GrantType)
- > Autenticação via API (oAuth2 Password GrantType)
- > Assinatura

1- Registro de aplicações

É um serviço público, que não requer uma pré-autenticação, o registro da aplicação pode ser simples (sem certificado digital) ou registro com assinatura digital (Com um Certificado Digital ICP Brasil - Equipamento).

Na modalidade de registro com assinatura digital, deve ser enviado um parâmetro único (signed_info) na requisição, onde deve conter uma assinatura PKCS7 attached com um JSON com os parâmetros 'name, comments e redirect_uris'

PATH	/application			
Method	POST			
Headers	<table><tr><td>Content-Type</td><td>application/json</td></tr></table>		Content-Type	application/json
Content-Type	application/json			

	<table><tr><td>Accept</td><td>application/json</td></tr></table>	Accept	application/json										
Accept	application/json												
Request	<table><tr><td>client_id</td><td>CNPJ base da aplicação (antes da "/").</td></tr><tr><td>client_secret</td><td>Senha/Segredo da aplicação.</td></tr><tr><td>signed_info</td><td>(opcional) Deve ser enviado somente quando utilizado o cadastro com certificado digital</td></tr><tr><td>name</td><td>Nome/Descrição da aplicação</td></tr><tr><td>comments</td><td>(opcional) Observações gerais de uso da aplicação.</td></tr><tr><td>redirect_uris</td><td>(opcional) URI's autorizadas para redirecionamento (para tokens do tipo 1).</td></tr></table> Exemplo: <pre>{ "client_id": "(CNPJ da aplicação)", "client_secret": "(Senha/Segredo da aplicação)", "name": "(Nome/Descrição da aplicação)", "comments": "(Observações gerais de uso da aplicação)", "redirect_uris": ["URI 1 pré cadastrada para redirecionamento", "URI 2 pré cadastrada para redirecionamento", "URI N pré cadastrada para redirecionamento"] }</pre>	client_id	CNPJ base da aplicação (antes da "/").	client_secret	Senha/Segredo da aplicação.	signed_info	(opcional) Deve ser enviado somente quando utilizado o cadastro com certificado digital	name	Nome/Descrição da aplicação	comments	(opcional) Observações gerais de uso da aplicação.	redirect_uris	(opcional) URI's autorizadas para redirecionamento (para tokens do tipo 1).
client_id	CNPJ base da aplicação (antes da "/").												
client_secret	Senha/Segredo da aplicação.												
signed_info	(opcional) Deve ser enviado somente quando utilizado o cadastro com certificado digital												
name	Nome/Descrição da aplicação												
comments	(opcional) Observações gerais de uso da aplicação.												
redirect_uris	(opcional) URI's autorizadas para redirecionamento (para tokens do tipo 1).												
Response	<pre>{ "status": "success", "message": "Aplicação cadastrada com sucesso" }</pre>												
Response - StatusCode	<table><tr><td>INVALID_PARAM</td></tr><tr><td>INVALID_CLIENT_ID</td></tr><tr><td>APPLICATION_CREATED</td></tr></table>	INVALID_PARAM	INVALID_CLIENT_ID	APPLICATION_CREATED									
INVALID_PARAM													
INVALID_CLIENT_ID													
APPLICATION_CREATED													

2- Autenticação de aplicação

O tipo de concessão "client credentials" é usado apenas para os serviços de registro de aplicação (**/application**), mas não permite acesso ao uso de chaves dos usuários.

A aplicação pode utilizar esse tipo de token para fazer, manter seu registro e utilizar para listagem de informações públicas dos usuários vinculados a aplicação.

PATH	/oauth/client_token	
Method	POST	
Headers	Content-Type	application/json
	Accept	application/json
Request	grant_type	Fixo: "client_credentials"
	client_id	Deve ter a identificação da aplicação.
	client_secret	Senha da aplicação
	lifetime	Opcional, indica o tempo de vida desejado para o token a ser gerado. Inteiro, em segundos.
	Exemplo: { "client_id": "MyApplicationId", "client_secret": "123qwe", "grant_type": "client_credentials", "lifetime": 900 }	
Response	access_token	Token de acesso
	token_type	Fixo: "Bearer"
	expires_in	Validade do token em segundos.
	Exemplo: { "access_token": "b923575f1ced0ee732ee274b2e02784040bd9606", "expires_in": 7200, "token_type": "Bearer" }	

3- Descoberta de usuário(s)

Serviço que disponibiliza uma listagem de certificados (parte pública) para uma aplicação. A aplicação pode especificar o usuário (CPF ou CNPJ), ou pedir de todos os registrados.

Para busca ampla (sem filtro), uma mensagem de ERRO será retornada se a aplicação tiver mais de 10 usuários registrados, indicando que a aplicação deverá fazer a solicitação especificando o usuário.

Na busca específica deve ser enviado o parâmetro “**document**” por querystring com o valor do CPF/CNPJ (somente números).

Exemplo:

https://<base_url>/user-discovery?document=<username>&certificate_alias=<alias-certificado>&return_chain=<true-ou-false>

PATH	/user-discovery	
Method	GET	
Headers	Content-Type	application/json
	Accept	application/json
	Authorization	Bearer <i>my_access_token</i> (Obtido no serviço - 2- Autenticação de aplicação)
Request	document	CPF/CNPJ do usuário (opcional)
	certificate_alias	Alias do certificado (opcional)
	rebuild_cache_after	Enviar data do cache atual, somente quando estiver filtrando pelo username através do parâmetro document (opcional) O parâmetro deve ser enviado no formato datetime (ano-mês-dia hora:minuto:segundo)
	return_chain	Flag para retorno da cadeia (opcional)

	<table border="1"> <tr> <td>return_chain_by_reference</td><td>Flag para retorno da cadeia no modo referência (opcional)</td></tr> <tr> <td>return_fields_format</td><td>Define formato das fields (hex or plain) (opcional)</td></tr> <tr> <td>return_additional_fields</td><td>Flag para envio de parâmetro adicionais (opcional)</td></tr> <tr> <td>return_user_photo</td><td>Flag para retorno do foto do usuário (opcional)</td></tr> </table>	return_chain_by_reference	Flag para retorno da cadeia no modo referência (opcional)	return_fields_format	Define formato das fields (hex or plain) (opcional)	return_additional_fields	Flag para envio de parâmetro adicionais (opcional)	return_user_photo	Flag para retorno do foto do usuário (opcional)
return_chain_by_reference	Flag para retorno da cadeia no modo referência (opcional)								
return_fields_format	Define formato das fields (hex or plain) (opcional)								
return_additional_fields	Flag para envio de parâmetro adicionais (opcional)								
return_user_photo	Flag para retorno do foto do usuário (opcional)								
Response	<pre>{ "certificates": [{ "alias": "CERTIFICADO TESTE LUAN:23524726100-2", "issuerDN": "C=BR, O=ICP-Brasil, OU=AC RAIZ teste v2, OU=AC SOLUTI teste v2, CN=AC SOLUTI Multipla teste v2", "certificate": "-----BEGIN CERTIFICATE-----cert-----END CERTIFICATE-----", "chain": [{ "subjectDN": "C=BR, O=ICP-Brasil, OU=AC RAIZ teste v2, OU=AC SOLUTI teste v2, CN=AC SOLUTI Multipla teste v2", "issuerDN": "C=BR, O=ICP-Brasil, OU=AC RAIZ teste v2, CN=AC SOLUTI teste v2", "certificate": "-----BEGIN CERTIFICATE-----cert-----END CERTIFICATE-----" }], { "subjectDN": "C=BR, O=ICP-Brasil, OU=AC RAIZ teste v2, CN=AC SOLUTI teste v2", "issuerDN": "C=BR, O=ICP-Brasil, CN=AC RAIZ teste v2", "certificate": "-----BEGIN CERTIFICATE-----cert-----END CERTIFICATE-----" }, { "subjectDN": "C=BR, O=ICP-Brasil, CN=AC RAIZ teste v2", "issuerDN": "C=BR, O=ICP-Brasil, CN=AC RAIZ teste v2", "certificate": "-----BEGIN CERTIFICATE-----cert-----END CERTIFICATE-----" }] }, "detail": { "code": 1109, "status": "CERTIFICATES_LISTED", } }</pre>								

	<pre> "message": "" } }</pre>				
Response - StatusCode	<table><tr><td>INVALID_ACCESS_TOKEN</td></tr><tr><td>USERS_EXCEEDED_MAXIMUM_ALLOWED</td></tr><tr><td>NO_CERTIFICATE_FOUND</td></tr><tr><td>CERTIFICATES_LISTED</td></tr></table>	INVALID_ACCESS_TOKEN	USERS_EXCEEDED_MAXIMUM_ALLOWED	NO_CERTIFICATE_FOUND	CERTIFICATES_LISTED
INVALID_ACCESS_TOKEN					
USERS_EXCEEDED_MAXIMUM_ALLOWED					
NO_CERTIFICATE_FOUND					
CERTIFICATES_LISTED					

3.1- Verificar existência de conta

Serviço disponibilizado para verificar se um usuário existe na base.

https://<base_url>/oauth/user-discovery

PATH	/oauth/user-discovery	
Method	POST	
Headers		
	Content-Type	application/json
	Accept	application/json
Request		
	client_id	Deve conter a identificação da aplicação.
	client_secret	Senha da aplicação.
	user_cpf_cnp	Deve conter “CPF” para pessoa física ou “CNPJ” pessoa jurídica.
	val_cpf_cnpj	Deve conter o valor do cpf ou cnpj.
	Exemplo: <pre>{ "client_id": "MyApplicationId", "client_secret": "123qwe", "user_cpf_cnp": "CPF", "val_cpf_cnpj": "12345678901" }</pre>	

Response		
	status	“S” para resultado positivo ou “N” caso contrário.
	slots	Matriz com os alias de slots encontrados, composto pelos pares ordenados slot_alias e label.

Exemplo:

```
{
  "status": "S",
  "slots": [
    {
      "slot_alias": "12345678901",
      "label": "HSM 12345678901"
    }
  ]
}
```

4- Autenticação de usuário(s)

Existem duas formas para autenticação de usuário, a primeira é mais recomendada para o cenário de aplicações WEB. Nessa modalidade é utilizado o OAuth2 - Grant Type - Authorization Code que funciona de forma semelhante ao conhecido “Logar com o Facebook”.

A segunda forma de autenticação pode ser utilizada em cenários onde não é possível redirecionar o usuário para uma página WEB (Ex: aplicação desktop). Nessa modalidade é utilizado o OAuth2 - Grant Type - Password.

Em ambas as formas de autenticação o usuário poderá selecionar o tempo de vida da sessão e o escopo desejado.

Existem três escopos OAuth que podem ser utilizados:

- **single_signature**: Token que permite a assinatura de apenas um hash, sendo invalidado após a sua utilização.
- **multi_signature**: Token que permite a assinatura de múltiplos hashes em uma única requisição, sendo invalidado após a sua utilização.
- **signature_session**: Token de sessão OAuth que permite várias assinaturas em várias chamadas à API, desde que o token esteja dentro do prazo de validade ou que não tenha sido revogado pela aplicação ou pelo usuário.

São escopos para os tokens de acesso à chave do usuário (Authorization Code e Password). Não há escopos definidos para serviços de aplicação sem acesso à chave do usuário (Client Credentials).

Em ambas as formas de autenticação no final do workflow de cada uma, a aplicação receberá o token de acesso (access_token) que será necessário para utilização dos serviços criptográficos em nuvem.

4.1- Autenticação OAuth2 - Grant Type Authorization Code

4.1.1- Authorization Code Request

A aplicação que está realizando a integração deve redirecionar o usuário para uma URL construída no seguinte formato:

Parâmetros da requisição (na query string, método GET):

PATH	/oauth/authorize
response_type	Fixo: "code".
client_id	Deve ter a identificação da aplicação.
redirect_uri	Opcional, deve ter a URI para redirecionar o usuário de volta para a aplicação de origem. A URI deve estar na lista de URI's autorizadas para a aplicação. Deve ser URL ENCODED. Se não informado, será considerada a primeira URI cadastrada para a aplicação.
state	Opcional, é retornado sem modificações para aplicação de origem.
lifetime	Opcional, indica o tempo de vida desejado para o token a ser gerado. Inteiro, em segundos.
scope	Opcional. Se não informado, será considerado "single_signature" . (ver lista de escopos acima)

O usuário será redirecionado para página da solução onde as credenciais deverão ser informadas, após a devida autenticação e autorização o usuário é redirecionado para a página apontada pelo cliente da solução.

Retorno:

O usuário é redirecionado para **redirect_uri** com dois parâmetros na query string: **code** (o código de autorização a ser usado na solicitação do token) e **state** (da mesma forma que informado na requisição inicial).

4.1.2- Exchange Code for Access Token

Após o usuário ser direcionado de volta para aplicação de origem, a aplicação que está realizando a integração deverá consumir em background o endpoint para recuperar o token OAuth.

Parâmetros da requisição:

PATH	/oauth/token	
Method	POST	
Headers	Content-Type	application/json
	Accept	application/json
Request	grant_type	Fixo: "authorization_code"
	client_id	Deve ter a identificação da aplicação.
	client_secret	Senha/Segredo da aplicação.
	code	Código de autorização retornado na redirect_uri
	redirect_uri	Opcional, deve ser igual ao informado no "Authorization Code Request".
	Exemplo:	
	{ "redirect_uri": "https://idg.receita.fazenda.gov.br", "client_id": "MyApplicationId", "client_secret": "123qwe", "code": "09b30f74d40a7fece1a26cccc97746c364e61022", "grant_type": "authorization_code" }	
Response	access_token	Token de acesso
	token_type	Fixo: "Bearer"
	expires_in	Validade do token em segundos.
	scope	Opcional. Deve ser informado se o scope retornado for diferente do solicitado pela aplicação.
	Exemplo:	
	{ "access_token": "b923575f1ced0ee732ee274b2e02784040bd9606", "expires_in": 7200, }	

	<pre>"token_type": "Bearer" }</pre> OBS: Não será permitido o refresh_token.
--	--

4.2- Autenticação OAuth2 - Grant Type Password

A aplicação cliente da solução deve solicitar ao usuário as credenciais de acesso antes de fazer a requisição.

PATH	/oauth	
Method	POST	
Headers	Content-Type	application/json
	Accept	application/json
Request	grant_type	Fixo: "password"
	client_id	Deve ter a identificação da aplicação.
	client_secret	Senha/Segredo da aplicação.
	username	Identificação do usuário (CPF ou CNPJ).
	password	Credenciais informadas pelo usuário.
	lifetime	Opcional, indica o tempo de vida desejado para o token a ser gerado. Inteiro, em segundos.
	scope	Opcional. Se não informado, será considerado "single_signature" . <i>(ver lista de escopos acima)</i>
	Exemplo:	
	<pre>{ "client_id": "MyApplicationId", "client_secret": "123qwe", "username": "0660457192", "password": "123456SENHA", "grant_type": "password", "scope": "single_signature", "lifetime": 900 }</pre>	

Response		
	access_token	Token de acesso
	token_type	Fixo: "Bearer"
	expires_in	Validade do token em segundos.
	scope	Escopo da autenticação
Exemplo:		
<pre>{ "access_token": "b923575f1ced0ee732ee274b2e02784040bd9606", "expires_in": 7200, "token_type": "Bearer" }</pre>		

5 - Assinatura em nuvem

Na modalidade assinatura em nuvem (via API) só podem ser enviado os hashes dos documentos.

Os hashes estarão em hexadecimal. Se mais de um hash for informado mas o scope do token for de apenas uma assinatura, uma mensagem de erro deve ser retornada.

Podem ser realizadas assinaturas no formato RAW (ASN1 PKCS#1 v1.5), CMS-detached ou CAdES-detached.

Obs:

Para simplificar o uso dos demais serviços de assinatura padronizadas (CMS, PDF Signature, XMLDsig, CAdES, PAdEs, XAdEs etc. Conheça também os serviços de ‘Vault Cloud Provider PKCS11’, ‘Vault Cloud Provider JCA’ e/ou ‘CESS - CertillionID Enterprise Signature Service’

PATH	/signature	
Method	POST	
Headers		
	Content-Type	application/json
	Accept	application/json
	Authorization	Bearer <i>my_access_token</i> (Obtido no serviço 4.1- Autenticação OAuth2 - Grant Type Authorization Code ou 4.2- Autenticação OAuth2 - Grant Type Password)

Request	<table> <tr> <td>certificate_alias</td><td>Alias do certificado (opcional)</td></tr> <tr> <td>hashes</td><td> Conjunto com valores a serem assinados. Cada elemento do conjunto conterá: <table> <tr> <td>id</td><td>identificador do conteúdo a ser assinado;</td></tr> <tr> <td>alias</td><td>forma legível do identificador do conteúdo;</td></tr> <tr> <td>hash</td><td>conteúdo a ser assinado;</td></tr> <tr> <td>signature_format</td><td> Opções: • RAW - Assinatura PKCS#1 v1.5 • CMS - Assinatura CMS-detached utilizando o hash (SHA256) no campo messageDigest • CAdES - Assinatura CAdES-detached utilizando o hash (SHA256) no campo messageDigest </td></tr> <tr> <td>include_chain</td><td>(opcional) Inclui cadeia do certificado do assinante na assinatura; (true or false)</td></tr> </table> </td></tr> </table> Ex: <pre>{ "certificate_alias": "cert001abc", "hashes": [{ "id": "Signature request ID 1", "alias": "Contrato de aluguel XPTO", "hash": "hash do conteúdo raw (atributos assinados)", "signature_format": "RAW" }, { "id": "Signature request ID 2", "alias": "Documento do Word", "hash": "hash do arquivo original -message digest", "signature_format": "CMS" }] }</pre>	certificate_alias	Alias do certificado (opcional)	hashes	Conjunto com valores a serem assinados. Cada elemento do conjunto conterá: <table> <tr> <td>id</td><td>identificador do conteúdo a ser assinado;</td></tr> <tr> <td>alias</td><td>forma legível do identificador do conteúdo;</td></tr> <tr> <td>hash</td><td>conteúdo a ser assinado;</td></tr> <tr> <td>signature_format</td><td> Opções: • RAW - Assinatura PKCS#1 v1.5 • CMS - Assinatura CMS-detached utilizando o hash (SHA256) no campo messageDigest • CAdES - Assinatura CAdES-detached utilizando o hash (SHA256) no campo messageDigest </td></tr> <tr> <td>include_chain</td><td>(opcional) Inclui cadeia do certificado do assinante na assinatura; (true or false)</td></tr> </table>	id	identificador do conteúdo a ser assinado;	alias	forma legível do identificador do conteúdo;	hash	conteúdo a ser assinado;	signature_format	Opções: • RAW - Assinatura PKCS#1 v1.5 • CMS - Assinatura CMS-detached utilizando o hash (SHA256) no campo messageDigest • CAdES - Assinatura CAdES-detached utilizando o hash (SHA256) no campo messageDigest	include_chain	(opcional) Inclui cadeia do certificado do assinante na assinatura; (true or false)
certificate_alias	Alias do certificado (opcional)														
hashes	Conjunto com valores a serem assinados. Cada elemento do conjunto conterá: <table> <tr> <td>id</td><td>identificador do conteúdo a ser assinado;</td></tr> <tr> <td>alias</td><td>forma legível do identificador do conteúdo;</td></tr> <tr> <td>hash</td><td>conteúdo a ser assinado;</td></tr> <tr> <td>signature_format</td><td> Opções: • RAW - Assinatura PKCS#1 v1.5 • CMS - Assinatura CMS-detached utilizando o hash (SHA256) no campo messageDigest • CAdES - Assinatura CAdES-detached utilizando o hash (SHA256) no campo messageDigest </td></tr> <tr> <td>include_chain</td><td>(opcional) Inclui cadeia do certificado do assinante na assinatura; (true or false)</td></tr> </table>	id	identificador do conteúdo a ser assinado;	alias	forma legível do identificador do conteúdo;	hash	conteúdo a ser assinado;	signature_format	Opções: • RAW - Assinatura PKCS#1 v1.5 • CMS - Assinatura CMS-detached utilizando o hash (SHA256) no campo messageDigest • CAdES - Assinatura CAdES-detached utilizando o hash (SHA256) no campo messageDigest	include_chain	(opcional) Inclui cadeia do certificado do assinante na assinatura; (true or false)				
id	identificador do conteúdo a ser assinado;														
alias	forma legível do identificador do conteúdo;														
hash	conteúdo a ser assinado;														
signature_format	Opções: • RAW - Assinatura PKCS#1 v1.5 • CMS - Assinatura CMS-detached utilizando o hash (SHA256) no campo messageDigest • CAdES - Assinatura CAdES-detached utilizando o hash (SHA256) no campo messageDigest														
include_chain	(opcional) Inclui cadeia do certificado do assinante na assinatura; (true or false)														

	<pre> }, { "id": "Signature request ID n", "alias": "Documento do Word 2", "hash": "hash do arquivo original -message digest", "signature_format": "CAAdES", "include_chain": true }] }</pre>
Response	<pre> { "status": "success", "message": "Hashes assinados com sucesso", "signatures": [{ "id": "Signature request ID 1", "raw_signature": "my raw signature base64" }, { "id": "Signature request ID 2", "raw_signature": "-----BEGIN PKCS7-----\n my CMS signature encoded PEM \n-----END PKCS7-----" }, { "id": "Signature request ID n", "raw_signature": "-----BEGIN PKCS7-----\n my CAAdES signature encoded PEM \n-----END PKCS7-----" }] }</pre>

6 - Revoke Session (Token)

Um access token poderá ser revogado a qualquer momento sem nenhum tipo de prévia autenticação.

PATH	/oauth/revoke	
Method	POST	
Headers		
	Content-Type	application/json
	Accept	application/json

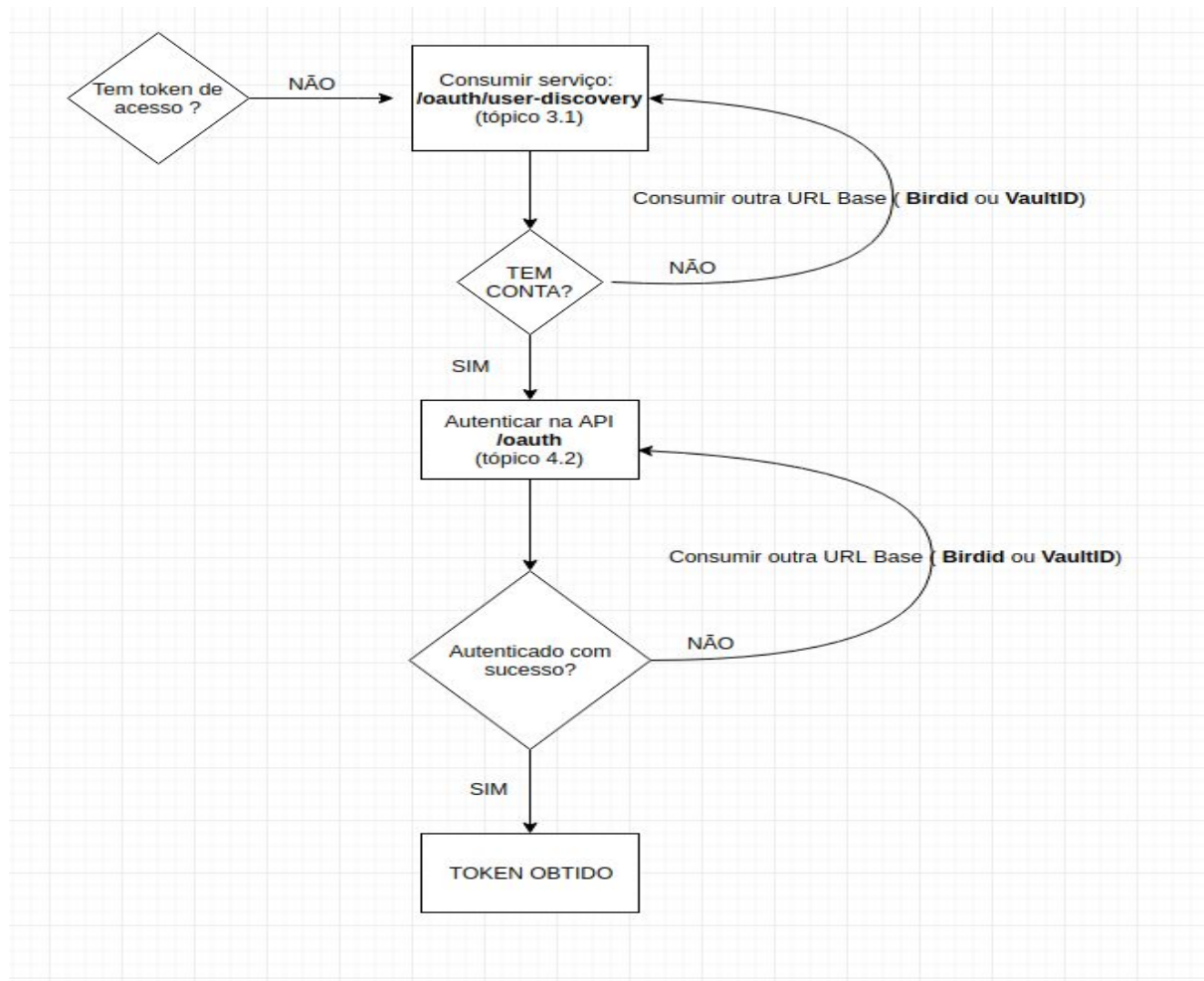
Request	<table border="1" data-bbox="443 241 1378 309"> <tr> <td data-bbox="443 241 646 309">token</td><td data-bbox="646 241 1378 309">Access Token a ser revogado</td></tr> </table> Exemplo: <pre data-bbox="443 353 1378 454">{ "token": "fbe5efdd0f05acc00912081cdbace6389e70936c" }</pre>	token	Access Token a ser revogado
token	Access Token a ser revogado		
Response	<table border="1" data-bbox="443 521 1209 622"> <tr> <td data-bbox="443 521 687 622">revoked</td><td data-bbox="687 521 1209 622">Confirmação de token inválido/revogado.</td></tr> </table> Exemplo: <pre data-bbox="443 667 667 768">{ "revoked": true }</pre>	revoked	Confirmação de token inválido/revogado.
revoked	Confirmação de token inválido/revogado.		

7 - Multi-nuvem

Caso o software que esteja integrando com a API possua certificado nas duas nuvens (Vaultid - <https://apicloudid.vaultid.com.br> - e BirdID - <https://api.birdid.com.br>), deverá utilizar ambas API's, conforme o fluxograma abaixo.

7.1 - Autenticação

Ao integrar no multi-nuvem, a aplicação deverá utilizar ambas APIs. Primeiramente, deverá consumir serviço para verificar se o usuário possui conta nesse endpoint (importante consultar esse serviço antes de autenticar para evitar bloqueio do usuário/aplicação).



7.2 - Assinatura

Após obtido o token de acesso, caso a aplicação não tenha a referência de qual endpoint seja o token de acesso, deverá consumir o user-discovery para armazenar essa referência (para não precisar fazer várias requisições em todas as assinaturas); caso tenha essa referência, basta consumir o serviço /signature.

